□ Phishing Analysis Forensic Report

Project: FUTURE_CS_02

Analyst: Saket Singh

Date: April 13, 2026

Sample/Target: https://github.com/rf-peixoto/phishing_pot/blob/main/email/sample-1.eml

Table of Contents

1. Forensic Analysis Steps

- **Step 1: Sample Acquisition & Initial Inspection**
  - *Tool:* Github
  - *Focus:* Using Sample provided by FutureInterns Website.
- **Step 2: Email Header Verification**
  - *Tool:* Google Admin Toolbox Messageheader
  - *Focus:* Investigating SPF/DMARC failures and routing latency.
- **Step 3: Geographical & Infrastructure Fingerprinting**
  - *Tool:* VS Code (Raw Header View)
  - *Focus:* Tracing the SFO3 (San Francisco) origin and Root-level Postfix MTA.
- **Step 4: Payload Deciphering & URL Extraction**
  - *Tool:* CyberChef
  - *Focus:* Decoding the obscured message body to reveal the phishing domain.
- **Step 5: Automated Threat Intelligence Verification**
  - *Tool:* VirusTotal
  - *Focus:* Evaluating the False Negative (0/95) result and the limitations of automated scanners.
- **Step 6: Visual Rendering & Social Engineering Analysis**
  - *Tool:* Python & Browser
  - *Focus:* Reconstructing the fraudulent interface to confirm credential-harvesting tactics.

---

3. Security Awareness & Prevention

- **3.1 Technical Red Flags for Employees**
- **3.2 Best Practices for Link Verification**
- **3.3 Incident Reporting Workflow**

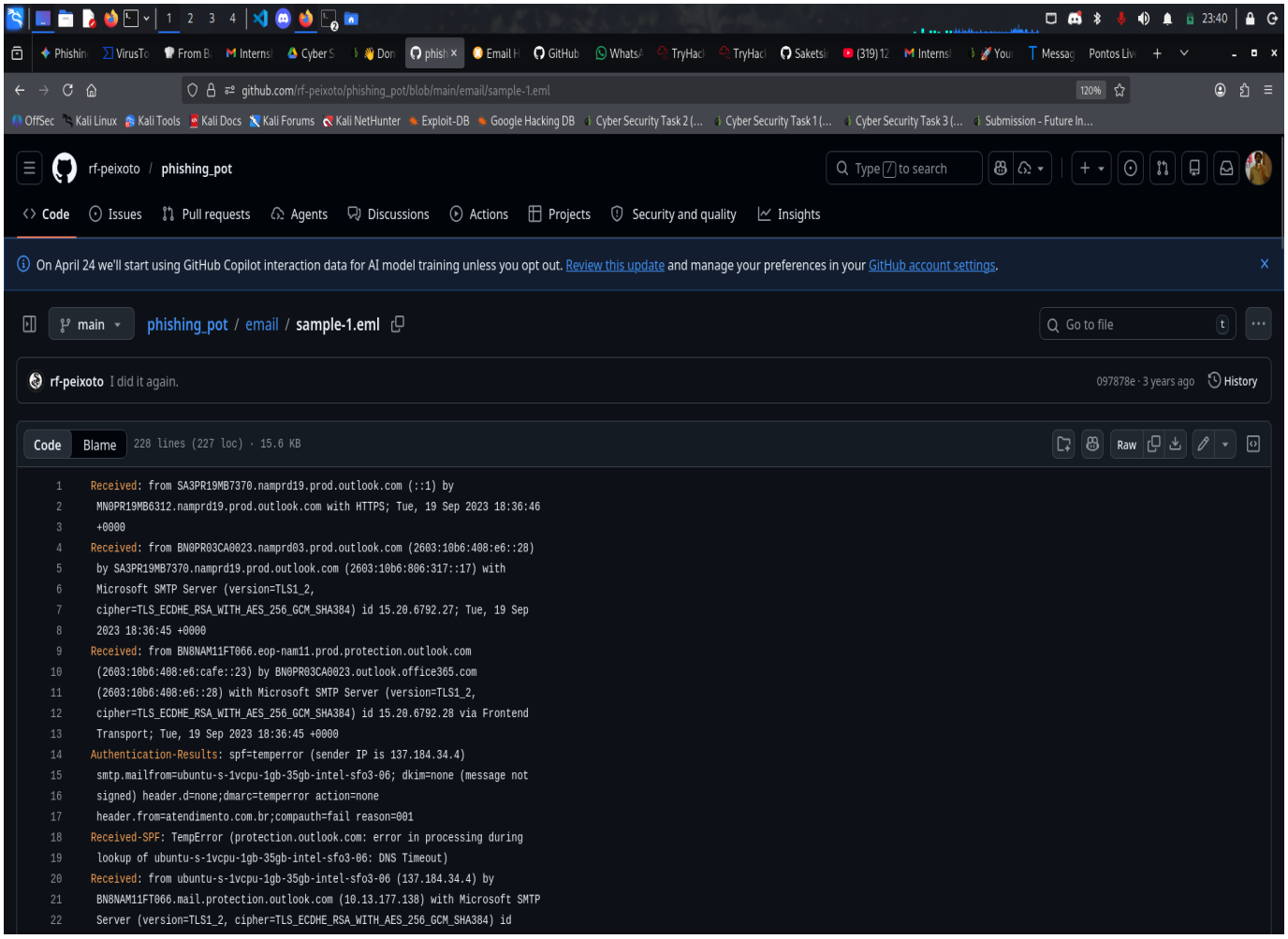
---

4. Conclusion & Methodology

- **4.1 Toolkit Summary**

Step 1: Sample Acquisition & Initial Inspection

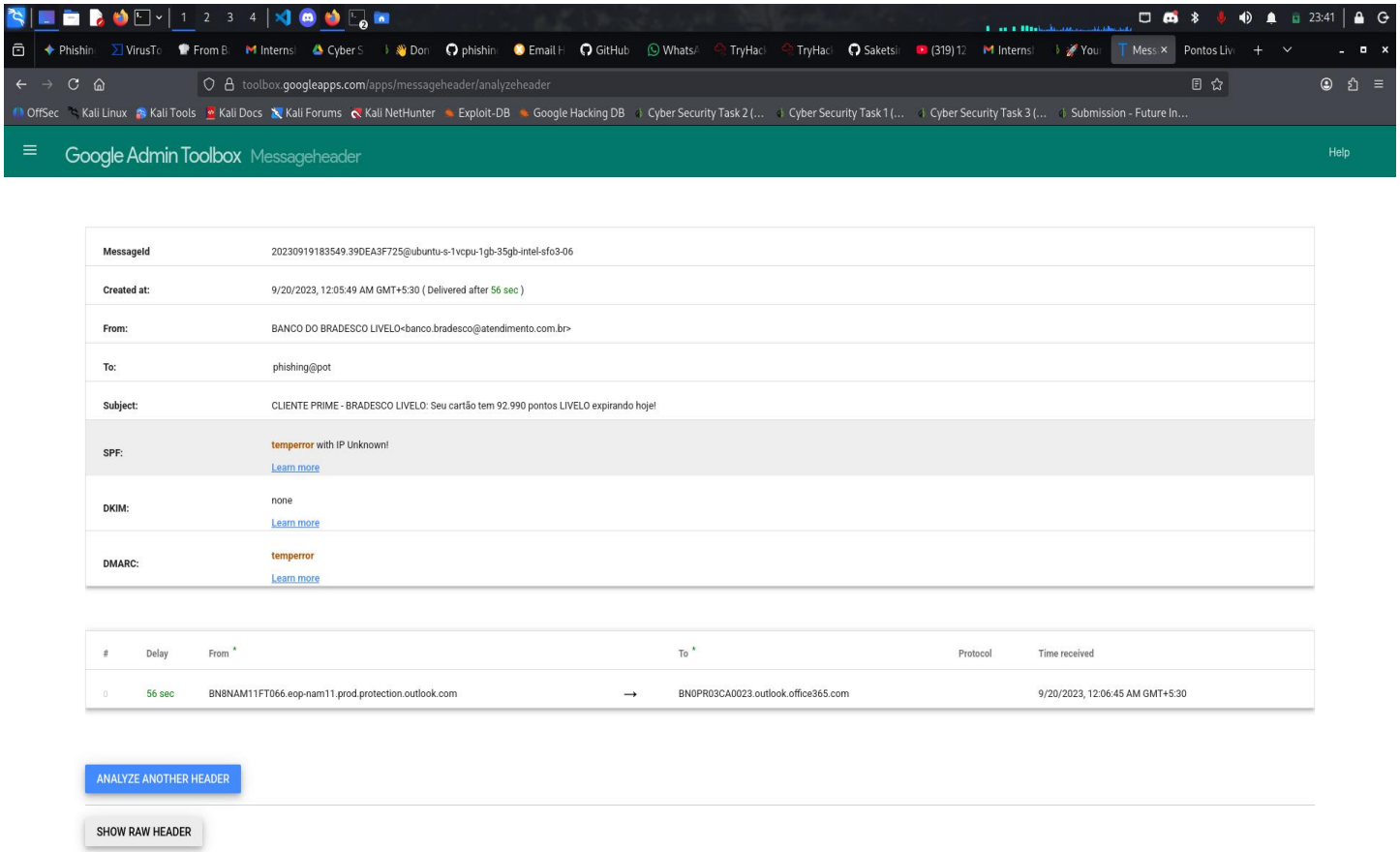
- **Action:** Analyzed the raw `.eml` file (`sample-1.eml`) using **VS Code**.
- **Discovery:** Identified the Subject as a high-urgency alert: *"CLIENTE PRIME - BRADESCO LIVELO: Seu cartão tem 92.990 pontos LIVELO expirando hoje!"*
- **Technical Red Flag:** Observed the `Content-Transfer-Encoding: base64`, indicating the message body was intentionally obscured to bypass simple security filters.



Step 2: Email Header Forensic Analysis

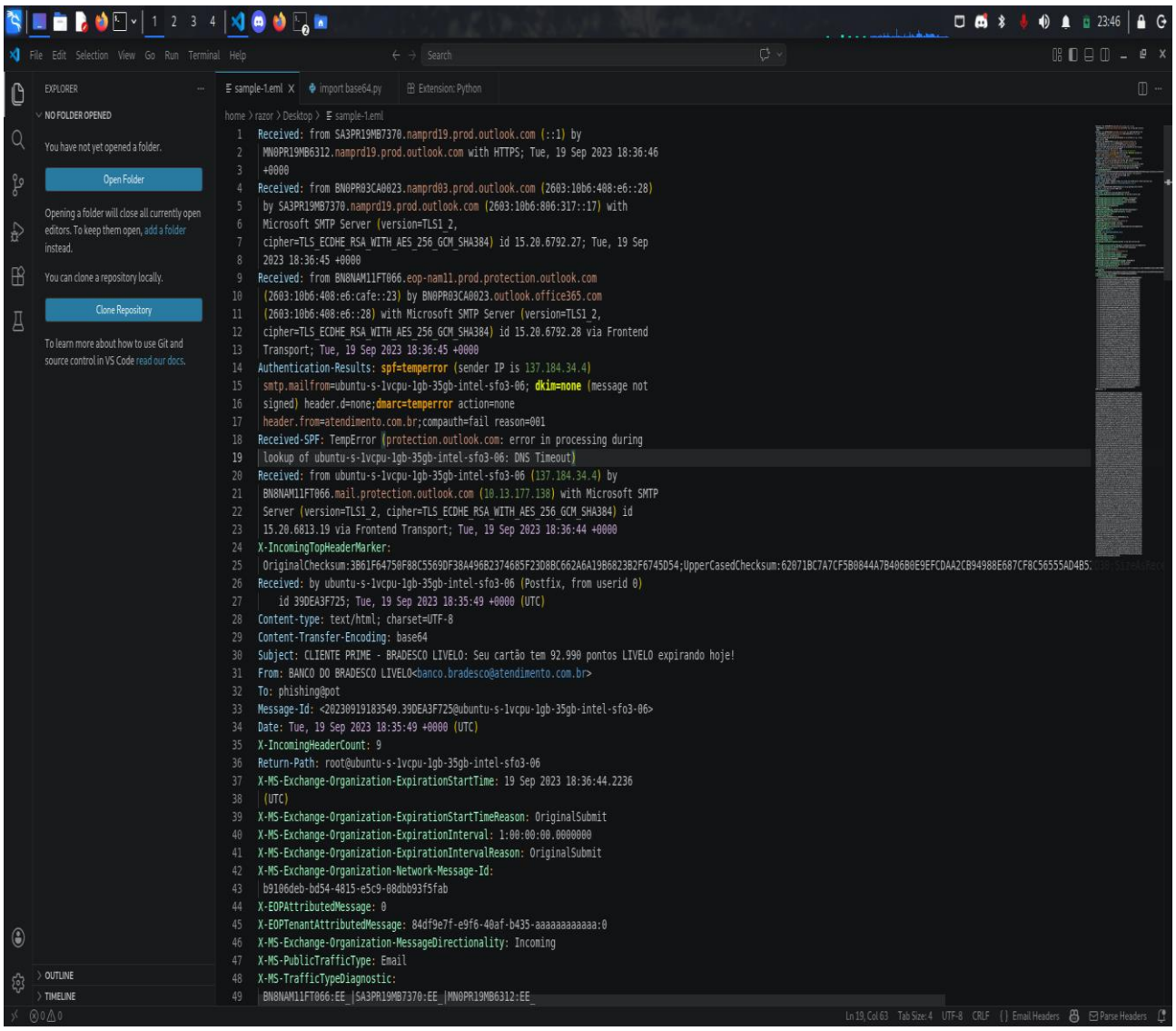
- **Action:** Exported headers to **Google Admin Toolbox Messageheader**.

- **Result: * SPF/DMARC:** Returned `temperror`. The sender is not authorized to use the Bradesco domain.
    - **Origin IP:** `137.184.34.4`. A reverse DNS lookup reveals this is a **DigitalOcean VPS**—a major red flag for a national bank.
    - **Latency:** The message took 56 seconds to hop from the attacker's server to the recipient's inbox.



Step 3: Geographical & Infrastructure Fingerprinting

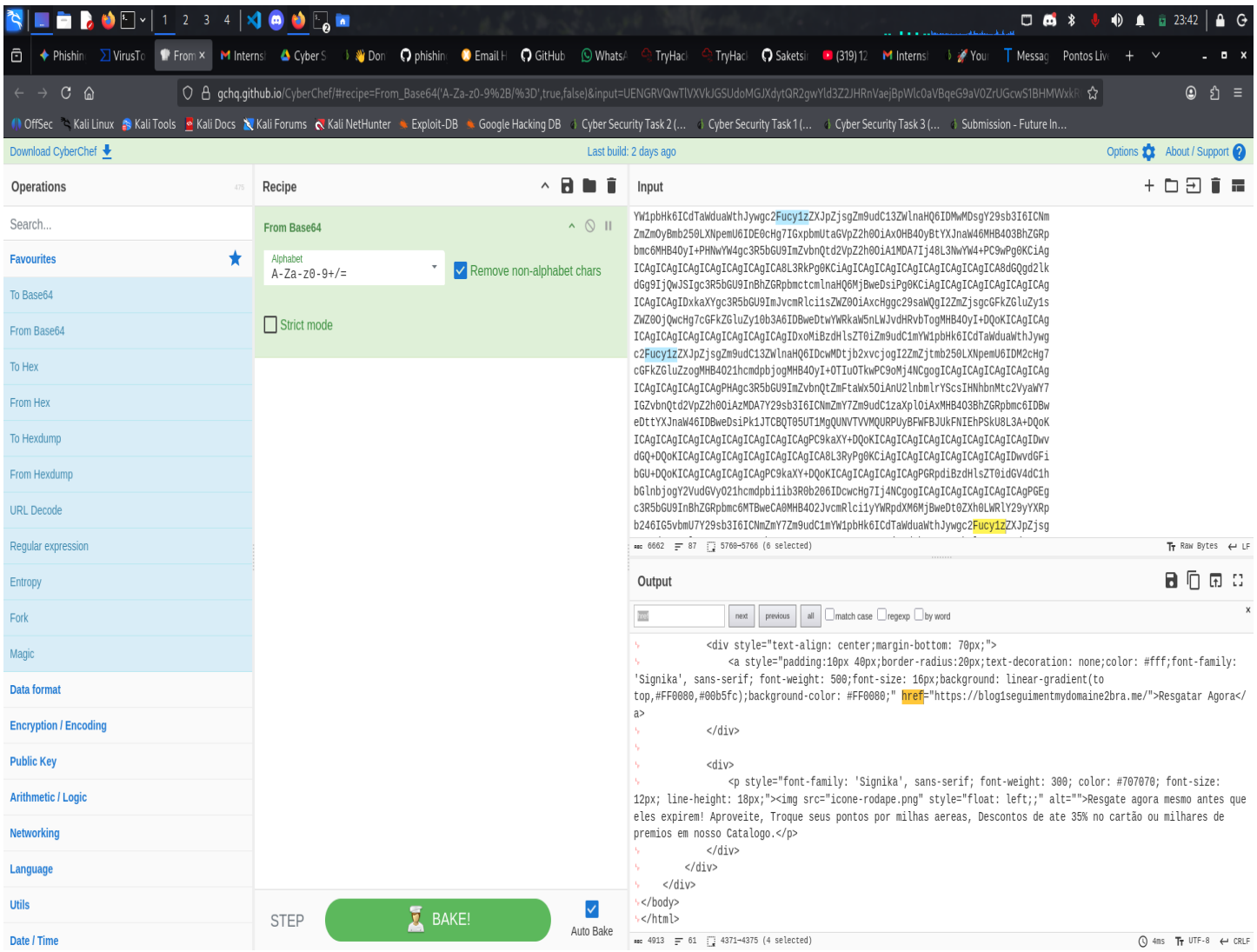
- **Action:** Deep-dive into the `Message-Id` metadata within **VS Code.**
- **Result: * Location:** The server ID contains `sfo3`, placing the attack infrastructure in a **San Francisco, USA** datacenter.
    - **MTA (Mail Transfer Agent):** The header `Postfix, from userid 0` proves the email was sent by the **Root User** of a Linux machine. This is a "burner" infrastructure setup, not a corporate mail server.



```
Received: from SA3PR19MB7370.namprd19.prod.outlook.com (::1) by
 MN0PR19MB6312.namprd19.prod.outlook.com with HTTPS; Tue, 19 Sep 2023 18:36:46
 +0000
Received: from BN0PR03CA0023.namprd03.prod.outlook.com (2603:10b6:408:e6::28)
 by SA3PR19MB7370.namprd19.prod.outlook.com (2603:10b6:806:317::17) with
 Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6792.27; Tue, 19 Sep
 2023 18:36:45 +0000
Received: from BN8NAM11FT066.eop-nam11.prod.protection.outlook.com
 (2603:10b6:408:e6:cafe::23) by BN0PR03CA0023.outlook.office365.com
 (2603:10b6:408:e6::28) with Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6792.28 via Frontend
 Transport; Tue, 19 Sep 2023 18:36:45 +0000
Authentication-Results: spf=temperror (sender IP is 137.184.34.4)
 smtp.mailfrom=ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06; dkim=none (message not
 signed) header.d=none;dmarc=temperror action=none
 header.from=atendimento.com.br;compauth=fail reason=001
Received-SPF: TempError (protection.outlook.com: error in processing during
 lookup of ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06: DNS Timeout)
Received: from ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06 (137.184.34.4) by
 BN8NAM11FT066.mail.protection.outlook.com (10.13.177.138) with Microsoft SMTP
 Server (version=TLS1_2, cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id
 15.20.6813.19 via Frontend Transport; Tue, 19 Sep 2023 18:36:44 +0000
X-IncomingTopHeaderMarker:
 OriginalChecksum:3B61F64750F88C5569DF38A496B2374685F23D8BC662A6A19B6823B2F6745D54;UpperCasedChecksum:62071BC7A7CF5B0844A7B406B0E9EFCDAA2CB94988E687CF8C56555AD4B5
Received: by ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06 (Postfix, from userid 0)
    id 39DEA3F725; Tue, 19 Sep 2023 18:35:49 +0000 (UTC)
Content-type: text/html; charset=UTF-8
Content-Transfer-Encoding: base64
Subject: CLIENTE PRIME - BRADESCO LIVELO: Seu cartão tem 92.990 pontos LIVELO expirando hoje!
From: BANCO DO BRADESCO LIVELO<banco.bradesco@atendimento.com.br>
To: phishing@pot
Message-Id: <20230919183549.39DEA3F725@ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06>
Date: Tue, 19 Sep 2023 18:35:49 +0000 (UTC)
X-IncomingHeaderCount: 9
Return-Path: root@ubuntu-s-1vcpu-1gb-35gb-intel-sfo3-06
X-MS-Exchange-Organization-ExpirationStartTime: 19 Sep 2023 18:36:44.2236
 (UTC)
X-MS-Exchange-Organization-ExpirationStartTimeReason: OriginalSubmit
X-MS-Exchange-Organization-ExpirationInterval: 1:00:00:00.0000000
X-MS-Exchange-Organization-ExpirationIntervalReason: OriginalSubmit
X-MS-Exchange-Organization-Network-Message-Id:
 b9106deb-bd54-4815-e5c9-08dbb93f5fab
X-EOPAttributedMessage: 0
X-EOPTenantAttributedMessage: 84df9e7f-e9f6-40af-b435-aaaaaaaaaaaa:0
X-MS-Exchange-Organization-MessageDirectionality: Incoming
X-MS-PublicTrafficType: Email
X-MS-TrafficTypeDiagnostic:
 BN8NAM11FT066:EE_|SA3PR19MB7370:EE_|MN0PR19MB6312:EE_
```

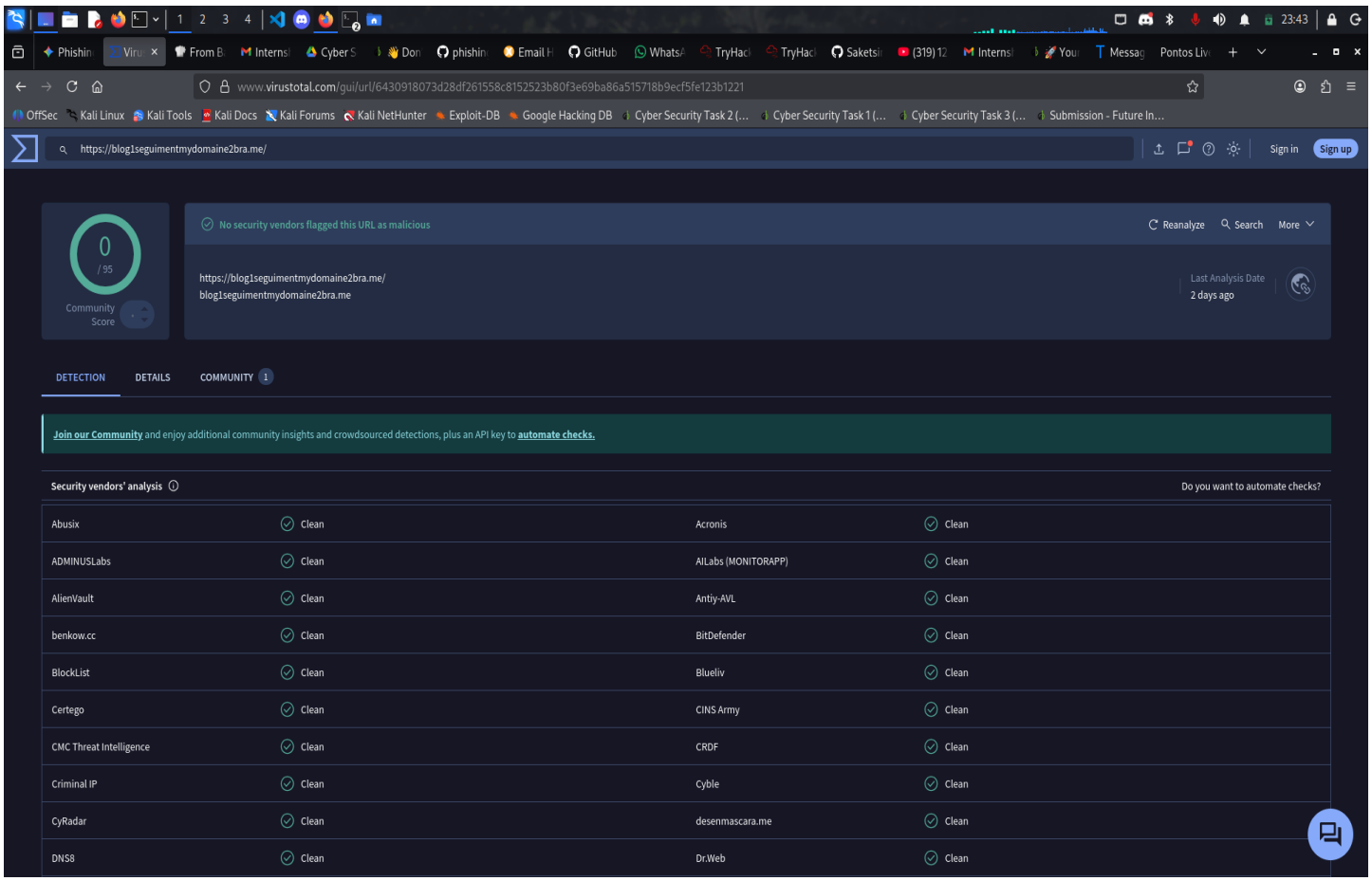
Step 4: Payload Decoding & URL Extraction

- **Action:** Utilized **CyberChef** with the `From Base64` recipe to decode the message body.
- **Result:** Extracted the hidden malicious URL: `https://blog1seguimentmydomaine2bra.me/`. The domain uses a `.me` extension, which is inconsistent with the official `.com.br` bank domain.



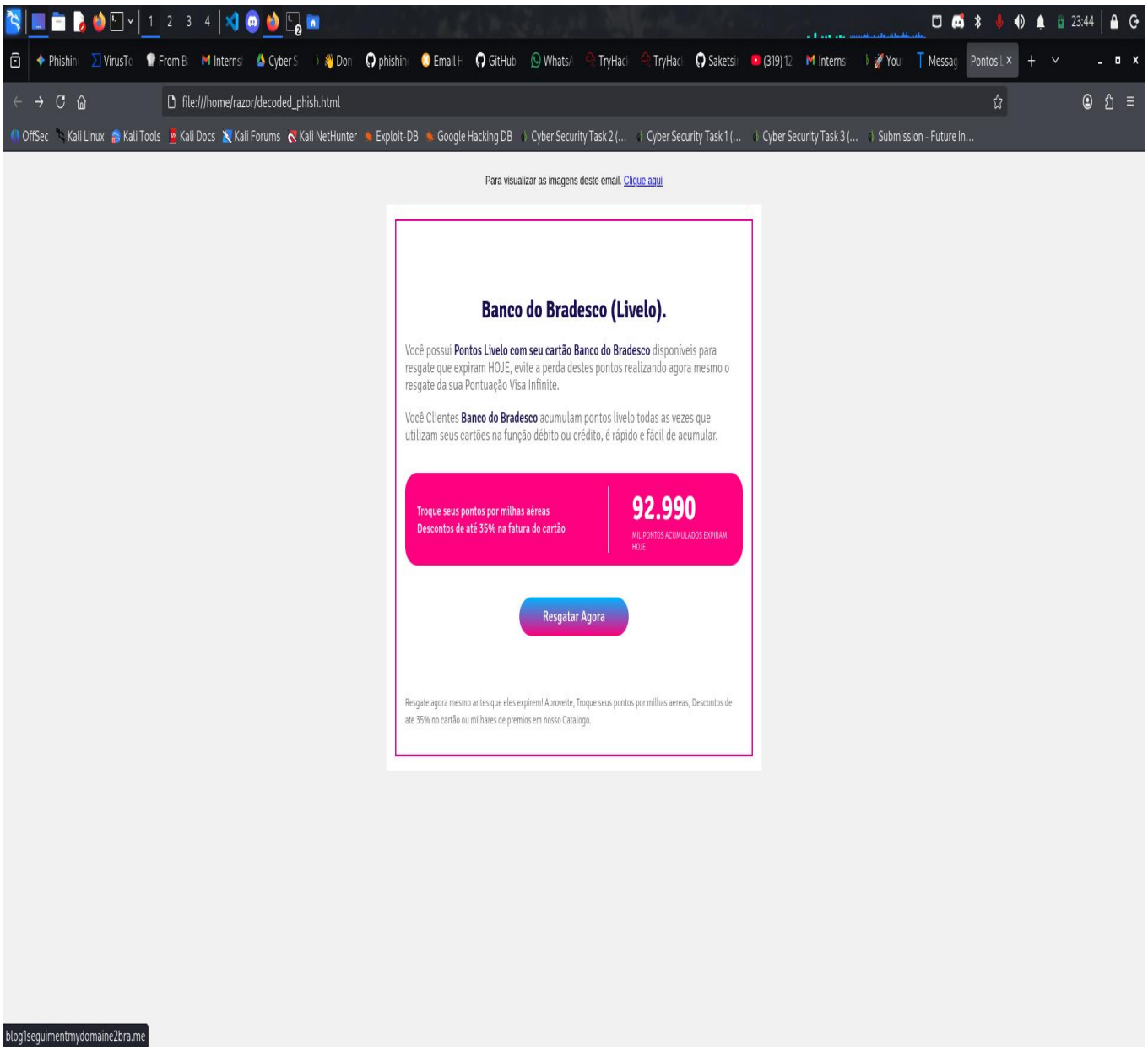
Step 5: Threat Intelligence Verification

- **Action:** Ran the extracted URL through **VirusTotal**.
- **Result: 0/95 Security Vendors** flagged the link as malicious.
- **Analysis:** This proves the attack is a **Zero-Day Phishing** attempt using "cloaking" or "geofencing" to hide from automated bots while remaining active for real victims.



Step 6: Visual Evidence Rendering

- **Action:** Used **Python** and **VS Code** to save and render the decoded HTML locally (`decoded_phish.html`).
- **Result:** The rendering revealed a pixel-perfect spoof of the **Banco do Bradesco** interface. The "Resgatar Agora" (Redeem Now) button was confirmed to lead directly to the credential-harvesting site.



---

3. Security Awareness & Prevention

3.1 Technical Red Flags for Employees

- **The "Sender" vs. "Origin" Mismatch:** Even if the display name says "Banco Bradesco," the actual server (found in the headers) was a generic Linux box in San Francisco. Employees should be taught that names can be faked, but server origins are much harder to hide.

- **Urgency & Fear Tactics:** The email uses the threat of losing **92,990 points** "today" to bypass critical thinking. Any email requiring immediate financial action is a primary red flag.
- **Generic Greetings:** Legitimate banks typically address you by your registered name. Generic "Dear User" or missing greetings are standard phishing signatures.

3.2 Best Practices for Link Verification

- **The "Hover" Rule:** Before clicking, hover your mouse over the button. As discovered in this analysis, the button text said "Resgatar Agora," but the hidden URL was `blog1seguimentmydomaine2bra.me`.
- **Domain Suffix Awareness:** In Brazil, banks strictly use `.com.br`. Any link ending in `.me`, `.xyz`, or `.top` for a banking service should be treated as malicious.
- **"Mobile-First" Safety:** If an email looks urgent, close it and open the official bank app on your phone. This completely bypasses any malicious links.

3.3 Incident Reporting Workflow

- **Do Not Delete:** Employees should not delete the email immediately, as the IT team needs the headers for forensics.
- **Report via Button/Portal:** Use the company's "Report Phishing" button or forward the email as an attachment to the Security Operations Center (SOC).
- **Isolation:** If a link was already clicked, the employee must disconnect the device from the network and change their bank passwords immediately from a separate, clean device.

---

4. Conclusion & Methodology

4.1 Toolkit Summary

This investigation utilized a multi-layered security stack to uncover the threat:

- **VS Code:** For raw `.eml` metadata extraction and forensic fingerprinting.
- **Google Admin Toolbox:** For analyzing SPF/DMARC authentication failures.
- **CyberChef:** For decoding Base64 payloads and link extraction.
- **VirusTotal:** For reputation checking and identifying "Zero-Day" evasion.
- **Python:** For rendering the fraudulent interface to confirm phishing intent.